

上海生声不息科技有限公司网络安全整改报告

上海市浦东新区网络与信息安全信息通报中心：

收到《关于落实网络安全隐患整改的通知》（沪浦网信安通〔2026〕267号）后，我司高度重视，由法定代表人、网络安全主要负责人邱生峰牵头，立即对通报所涉网站、数据库、账号权限、客户端代码、服务器暴露面和相关日志开展自查整改。2026年7月30日完成通报隐患的生产封堵，2026年8月5日再次从公网复测确认整改措施持续有效。现将有关情况报告如下：

一、基本情况

（一）单位和在用系统情况

上海生声不息科技有限公司（统一社会信用代码：91310115MAK7L93M8Y）成立于2026年3月16日，注册资本人民币50万元，住所为中国（上海）自由贸易试验区新金桥路498号8幢19号楼3层，所属行业为软件和信息技术服务业，主要从事人工智能语音辅助产品的研发与运营。公司为独立市场主体，无上一级主管部门，依法接受网信、公安、通信管理、市场监督管理等部门的监督管理。公司法定代表人邱生峰为现阶段网络安全主要负责人，负责网络安全工作统筹、权限审批、事件处置和对外联络。

公司当前在用自建互联网信息系统为“VoxFlame 智能语音助手”（网站名称：VoxFlame，备案号：沪 ICP 备 2026020229 号），2026 年 4 月进入试运行，2026 年 5 月以正式域名对外提供服务。系统主要资产如下：

1. 网站及业务入口：<https://voxember.com>；
2. 公网 IP 地址：111.230.35.89，未划分独立互联网网段；
3. 对外服务端口：80、443；语音实时通信所需端口为 7880、7881、3478/UDP、7882/UDP；22 端口用于受控运维；
4. 前端、后端和运行时健康服务端口 3000、3001、8081 均仅监听本机回环地址，不直接向互联网开放；
5. Android 移动端目前处于内测阶段，复用同一账号体系、后端接口和数据边界，不另设独立互联网后端。

公司现阶段尚未完成网络安全等级保护定级备案。结合系统处理用户账号、语音训练记录、沟通会话和个性化记忆等数据的情况，公司拟先按网络安全等级保护第二级要求开展建设，并委托专业机构进行定级咨询，最终等级和备案要求以公安机关审核意见为准。

（二）被通报系统的功能、责任和技术架构

VoxFlame 是面向构音障碍者的人工智能语音辅助系统，主要提供实时语音沟通辅助、普通话训练、常用表达管理和个

性化沟通记忆等功能。系统可能处理用户账号标识、用户画像、会话记录、训练录音及转写、常用短语等数据。

系统由上海生声不息科技有限公司自主开发和维护，当前责任部门由公司法定代表人邱生峰直接负责。生产服务器托管于腾讯云轻量应用服务器；公网入口由 Caddy 提供 HTTPS 和反向代理；前端采用 Next.js，后端采用 Node.js 服务；实时语音链路采用自建 LiveKit 服务；账号认证和主要业务数据库使用 Supabase 托管服务。现役业务数据链路为“客户端认证—公司后端 API—数据库服务”，浏览器和移动端不直接读写用户业务数据表。

通报指出，网站客户端 JavaScript 中存在 Supabase 客户端 API 标识，检测人员可利用该标识注册测试账号，再使用普通用户访问令牌调用数据库 REST 接口，跨用户读取 sessions、user_profiles、memories 等数据。通报将该问题表述为“Supabase 凭据硬编码导致数据泄漏”，并称测试过程中可获取 AI 对话数据、记忆约 1750 条。

（三）当前安全防护技术措施

1. 网络入口统一使用 HTTPS，启用 HSTS、内容安全策略、点击劫持防护、MIME 嗅探防护、权限策略等安全响应头，隐藏不必要的服务指纹；

2. 前端、后端和运行时管理端口仅监听本机地址，通过反向代理对外提供服务；生产容器设置健康检查和自动重启策略；

3. 用户业务数据表启用并强制执行数据库行级安全控制（RLS），匿名角色和普通认证角色不具有敏感表的直接访问权限；

4. 后端服务账号按最小权限原则仅保留查询、新增、更新、删除所需权限，不授予截断、触发器或引用等非必要权限；

5. 高权限密钥、短信服务密钥等仅配置在后端环境中，不进入前端构建产物、提示词或业务日志；相关凭据文件设置最小文件权限；

6. 浏览器和移动端仅使用 Supabase 公共客户端标识完成身份认证。该标识不作为访问用户业务数据的授权依据，业务数据访问必须通过公司后端鉴权和数据库权限双重控制；

7. 已建立针对生产数据库公开访问边界的自动化回归脚本，能够在不输出密钥、不读取数据正文的情况下验证匿名访问是否被阻断、后端业务访问是否正常；

8. 已保留服务运行日志和事件处置记录，并正在按照《中华人民共和国网络安全法》关于网络日志留存不少于六个月的要求补齐统一采集、归档、检索和定期审查机制。

（四）事件发展、初判原因和损失排查

2026 年 7 月 9 日，检测人员通过互联网开展安全检测并创建测试账号 test1@poc.com；2026 年 7 月 23 日，我司收到沪浦网信安通〔2026〕267 号通知；收到通知后立即开展生产核查和整改；2026 年 7 月 30 日完成数据库权限封堵、代码封口和测试账号处置；2026 年 8 月 5 日再次完成公网复测。

经核查，本次问题并非后端高权限服务密钥泄露。Supabase 匿名客户端标识按其客户端认证架构需要随应用公开，但我司前期错误地将该公共标识与数据库安全边界混同，未对敏感业务表全面启用有效的行级安全控制，同时历史默认授权使匿名角色和普通认证角色保留了过宽的表级权限。当“公开客户端标识、可注册普通用户、敏感表权限过宽”三项条件叠加时，形成了跨用户读取风险。根本原因是数据访问控制配置和上线前安全审查不到位，而非单纯的前端字符串暴露。

我司自查确认整改前相关敏感表确实存在被匿名或普通认证角色读取的访问面。通知称检测过程中可获取约 1750 条数据；由于现有数据库状态不能反向证明检测人员实际查看、下载或留存的数据范围，当前无法仅凭记录总数准确确认实际访问数量。我司未发现数据被篡改、删除、勒索，未发现服务中断或高权限系统控制权被获取。通知中的测试账号在六张业务表中的记录数均为 0，最后登录时间为 2026 年 7 月 9 日，现已

长期停用；为配合后续取证，保留该账号的两条认证会话记录，不再使用。公司将继续结合可获得的认证、数据库、API 和服务器日志核验访问范围，如发现对个人或者组织合法权益造成危害，将依法及时履行通知、报告和补救义务。

二、整改情况

（一）针对通报问题采取的措施及效果评估

1. 立即封堵敏感表的公开访问。对

user_profiles、sessions、memories 三张通报涉及的敏感表启用并强制执行 RLS，撤销 PUBLIC、匿名角色和普通认证角色的全部表权限，使客户端公开标识和普通用户访问令牌均不能直接读取、写入、修改或删除上述数据。

2. 对全部同类数据表扩展收口。对

voice_contributions、quick_phrases、preset_phrases 同步启用并强制执行 RLS，清理历史宽松策略。voice_contributions 和 quick_phrases 对匿名角色、普通认证角色均关闭直接访问；preset_phrases 仅保留对不含用户数据的有效系统预设短语的只读访问，不授予任何新增、修改或删除权限。

3. 收紧后端服务账号权限。 对后端服务账号先撤销历史授权，再仅授予业务所需的 SELECT、INSERT、UPDATE、DELETE 权限，不授予 TRUNCATE 等非必要高风险权限；同步撤销 public 模式下新

建表和序列向浏览器角色自动授予权限的默认规则，防止后续新增表再次暴露。

4. 封闭客户端数据旁路。 删除前端未使用的数据库存储上传、训练数据直写、直接语料查询和旧 RPC 调用；浏览器仅保留身份认证能力，用户画像、会话、记忆、训练数据和常用短语等业务数据统一经公司后端 API 处理。后端数据库服务在缺少服务账号密钥时失败关闭，不再降级使用匿名客户端标识执行业务数据操作。

5. 处置事件账号并保留证据。 精确定位测试账号 test1@poc.com，确认其创建和最后登录均发生在 2026 年 7 月 9 日，已将该账号停用至 2126 年，阻止其重新登录。该账号在六张业务数据表中无业务记录；相关认证会话记录予以保全，便于后续关联来源 IP、用户代理和访问日志。

6. 修复其他密钥管理问题。 对代码和配置开展密钥排查，已将历史管理脚本中的 Supabase 高权限服务密钥移出源码，统一从后端受控环境读取；腾讯云短信等第三方凭据采用最小权限子账号并仅保存在后端，不向客户端、日志或运行时提示词传递。

7. 建立可重复验证。 新增核心敏感表和其余公开表两套生产访问回归脚本。脚本仅发送只读 HEAD 请求，不读取或输出业务数据正文，也不输出任何密钥；每次数据库权限变更后均可复测匿名边界和后端业务可用性。

整改效果经 2026 年 8 月 5 日公网复测如下：

1. 使用通知中公开的原匿名客户端标识访问 user_profiles、sessions、memories，均返回 HTTP 401；
2. 访问 voice_contributions、quick_phrases，均返回 HTTP 401；
3. 访问不含用户数据的有效系统预设短语返回 HTTP 200，且仅为批准的只读范围；
4. 后端服务账号访问上述业务表均返回 HTTP 200 或 206，证明整改未中断正常业务；
5. https://voxember.com 和 https://voxember.com/api/rtc/health 均返回 HTTP 200；未登录访问用户记忆接口返回 HTTP 401；
6. 生产前端、后端容器健康运行，业务服务正常。

综上，通报所述“使用客户端公开标识和普通用户令牌跨用户读取敏感业务数据”的路径已经被数据库授权、强制 RLS 和后端 API 鉴权多重阻断，整改达到预期效果。原匿名客户端标识目前仍用于 Supabase 客户端身份认证，但已不具备访问敏感业务数据的权限；后续将迁移至 Supabase 新式 publishable key 并再次复测，进一步降低旧式密钥体系造成的识别和管理风险。

（二）扩展排查情况

1. 对生产 public 模式下现有六张普通表完成逐表盘点，全部启用并强制执行 RLS；未发现可绕过上述边界访问用户数据的视图、物化视图、外部表或高权限 RPC 函数；

2. 对 Supabase Storage 进行核查，当前未配置存储桶、对象或自定义存储策略，未发现同类文件存储暴露；

3. 对服务器监听端口进行核查，前端 3000、后端 3001、运行时健康服务 8081 仅监听本机回环地址；公网仅保留网站、运维和实时语音通信所需端口；

4. 对公网 HTTPS 响应进行核查，HSTS、内容安全策略、点击劫持防护、MIME 嗅探防护和浏览器权限策略均已生效，未暴露 Next.js、Express 等不必要服务指纹；

5. 对生产运行状态进行核查，前端、后端、实时通信服务和语音代理服务均处于运行状态，前端和后端健康检查通过；

6. 对账号注册和安全运营配置进行核查，当前仍保留公开注册，邮箱自动确认尚未关闭，CAPTCHA 尚未全局启用；该事项未构成此次敏感表越权访问的继续条件，但属于账号滥用防护和纵深防御缺口，已纳入限期计划；

7. 对边界防护进行核查，腾讯云 EdgeOne/WAF 已完成基础配置，但权威 DNS 尚未切换，当前公网流量仍直接到达源站；源站访问控制和 WAF 正式接管已列入后续整改计划；

8. 对事件日志进行核查，现有日志能够支持部分运行排查，但尚未形成覆盖网站入口、后端 API、认证、数据库和云平台的统一六个月留存闭环，已列为优先整改事项。

三、后续工作

我司将以现行《中华人民共和国网络安全法》第二十三条规定的等级保护义务、第二十四条规定的漏洞补救和安全维护义务、第二十七条规定的应急预案和事件处置义务为主线，同时落实《网络数据安全条例》关于访问控制、安全认证、日志留痕、事件报告和受托处理监督的要求，结合公司现阶段主要由法定代表人邱生峰负责网络安全工作的实际，执行以下计划：

1. 落实网络安全责任制（2026 年 8 月 10 日前完成制度建档，持续执行）。明确法定代表人邱生峰为网络安全主要负责人，建立资产清单、数据清单、账号权限清单、第三方服务清单和安全风险台账。涉及数据库权限、生产密钥、网络边界和认证策略的变更，实行“变更前备份、变更内容复核、变更后自动化验证、结果留档”；在公司人员较少、无法长期设置独立安全岗位的阶段，对高风险变更引入第三方专业人员复核，避免单人操作形成新的盲区。

2. 推进网络安全等级保护（2026 年 9 月 30 日前完成定级咨询和材料准备）。依据《中华人民共和国网络安全法》第二十三条，委托专业机构梳理等级保护对象，拟先按第二级要求

建设和整改，向公安机关咨询定级备案流程，按审核意见完成定级、备案、安全建设整改和后续测评，不以“初创公司”或“系统规模较小”为由免除等级保护义务。

3. 建立不少于六个月的网络日志留存机制（2026年8月15日前完成首期落地）。 统一采集 Caddy 访问日志、后端 API 安全日志、认证审计日志、数据库访问日志、云平台安全日志和关键配置变更记录，统一时钟、日志格式和脱敏规则，采用按日轮转、加密归档和访问权限隔离方式留存不少于六个月。邱生峰每月检查异常登录、批量访问、连续 401/403、权限变更和高频注册等事件，形成月度检查记录；涉及委托处理的记录按规定至少保存三年。

4. 完善漏洞发现、处置和复测闭环（2026年8月15日前形成流程，持续执行）。 每月开展依赖漏洞、密钥泄漏、端口暴露和数据库权限检查，每季度至少开展一次互联网暴露面扫描，每年委托第三方开展一次安全评估。发现高风险漏洞后立即采取限流、停用入口、撤销权限或网络隔离等临时措施，原则上 24 小时内完成修复方案和风险评估，修复后必须由自动化脚本或独立人员复测；对可能危害国家安全、公共利益的安全缺陷，依法在规定时限内向主管部门报告。

5. 持续执行最小权限和密钥治理（2026年8月31日前完成首轮收口，每季度复核）。 将 Supabase 旧式 legacy anon key 迁移为新式 publishable key，迁移后使用原通报路径再

次验证敏感表仍为 401；高权限服务密钥仅保存在后端受控环境，禁止进入前端、代码仓库、日志、截图和提示词；服务账号按用途拆分，启用最小权限和多因素认证；每季度复核账号、角色、API 密钥和第三方子账号，人员或用途变化时立即撤权，发生疑似泄露时立即轮换。

6. 强化注册和身份认证安全（2026 年 8 月 31 日前完成）。 配置生产邮件服务，关闭邮箱自动确认，启用 Cloudflare Turnstile 或等效 CAPTCHA，并为 Web 端和移动端补齐验证令牌流程；结合预期注册量设置注册、登录、验证码、令牌刷新等速率限制；手机号、验证码、访问令牌和密钥均采用脱敏日志；对异常批量注册、撞库和暴力尝试设置阻断和告警。

7. 加强互联网边界防护（2026 年 8 月 31 日前完成首轮）。 完成腾讯云 EdgeOne 权威 DNS 切换并验证 WAF 托管规则实际接管流量；限制源站 80、443 端口的直接访问来源；SSH 采用密钥登录、最小来源范围和多因素保护；复核 LiveKit 信令、媒体和 TURN 端口的必要性及安全组范围，关闭无业务用途端口。每季度对公网 DNS、证书、安全组、WAF 策略和监听端口进行一次复核。

8. 加强数据分类分级和备份恢复（2026 年 9 月 15 日前完成首轮）。 按账号标识、用户画像、沟通会话、训练录音、语音转写和个性化记忆等数据类型建立分类分级清单，明确收集

目的、保存期限、访问主体和删除规则；敏感数据传输使用加密通道，备份数据加密保存并与生产权限隔离；每月检查备份状态，每季度开展一次恢复抽查，避免只备份、不验证恢复。

9. 完善第三方和供应链管理（2026年9月15日前完成首轮）。对腾讯云、Supabase、短信、模型服务、代码依赖和移动端构建服务建立供应商清单，审查其数据处理范围、权限、日志、事件通知和退出机制；涉及委托处理个人信息或重要数据的，通过合同或服务条款明确处理目的、方式、范围和安全责任，并监督履约情况。新增第三方服务必须先完成安全和数据影响评估，不得默认取得生产数据或高权限账号。

10. 完善事件应急和报告机制（2026年8月15日前形成预案，每半年演练）。制定账号泄露、越权访问、数据泄露、恶意注册、勒索和服务中断等场景的应急预案，明确“发现—研判—隔离—保全证据—修复—复测—报告—复盘”流程。发生网络安全事件时立即启动预案、控制危害扩大并保存证据，依法向有关主管部门报告；对个人或者组织合法权益造成危害的，依法告知相关主体。每半年至少开展一次桌面推演或实操演练，演练问题纳入整改台账。

11. 接受监督并持续改进（长期执行）。对本次整改SQL、访问回归结果、账号处置记录、构建验证、服务器端口和安全响应头核查结果分类归档；每次数据库迁移和生产发布

均执行权限回归检查；主动配合公安、网信等主管部门的检查和
技术指导，对新发现的问题及时整改、复测和报告。

我司将以本次通报为警示，切实履行网络运营者和网络数
据处理者的主体责任，持续提升安全管理和技术防护能力，防
止同类问题再次发生。

上海生声不息科技有限公司（加盖公章）

2026 年 8 月 5 日